

---

**Fairhaven Primary Audit Report****Audit Date: 22 January 2020****Report: Year 2 visit 1****DPE: Linda Mortimer****School member: Jan Chambers School Bursar / GDPR Governor****1. Visit details**

Details highlighted at the time of the last visit were discussed. GDPR documents and policies were also reviewed. This included DPE Best Practice areas, Compliance Checklists, SLA tool, Record of Processing and Compliance Manager being discussed and demonstrated to the school. The themed audit carried out by NCC in Summer Term 2019 was also talked through (refer to section 7 below) as well as when the need arises for completing a Data Protection Impact Assessment (DPIA), (refer to section 6.1 below).

**Review actions recommended at time of previous visit – 7.2.19**

All items raised at the time of the previous audit have been addressed with exception of:

**Visitor Signing In:** Having assessed other systems available, the school maintains an open book sign-in system. To minimise the risks associated with PII information easily accessible, the completed sign-in sheets are stored securely at the end of each day. This will be reviewed in the future, as there are long term plans in place regarding an expansion to the reception and admin office. The school are also planning to install keypad entry to the main office and Headteacher's office.

**Admin Office:** There are class lists on display, showing student's first name and surname as well as DOB. The school and GDPR Governor have assessed the risks of maintaining this practice. To reduce the risks associated with PII information on display, the lists will be covered from now on.

For all other lists eg Breakfast Club list, these will be amended to show first name only.

**DPE Recommendation:** Remove class lists during holidays when contractors may be onsite.

Folders containing budget paperwork going back a few years were also clearly visible. Please ensure these files are stored securely as they contain confidential information.

A list detailing staff's personal contact numbers is on display. This will be relocated to contact folder – please ensure this information is stored securely.

**Headteacher's Office:** Now has lockable cabinet in place for storage of sensitive data - SEND, PP, Safeguarding files

**Printer Codes:** School will explore possibility of assigning a pin code for admin / HT to allow secure printing of confidential papers – refer to Mark Hard at Konica Minolta.

---

## 2.Audit walk and findings on 22.1.20

**GDPR Policy:** The Policy is due for review in May 2020 and the school will adopt the latest DPE model policy.

**Privacy Notice:** The Privacy Notice needs to be amended to show a more detailed list of third parties with whom the school shares personal information. Visitors are signposted to the school's Privacy Notice on the school website.

**Training:** The school has completed DPE's GDPR 101 online training module for the majority of staff. There are now 5-10 minute learning nuggets available under the Training section on the Data Dashboard on Knowledge Bank and include Password Security, Physical Security, Clear Desk guidance and Data Breaches and SARs. There will be more information available shortly on KB regarding Data Protection Impact Assessments.

**DPE Data Breach, SAR and FOI Log:** The school uses the DPE online facilities to record and will also log any received Data Breaches.

**Naming convention:** All exercise books, work trays and coat pegs use first names only.

**Learn Pads:** Only used by students to access the internet and accounted for on a daily basis.

**Laptops:** Are encrypted, password protected and accounted for on a regular basis

**IT Technical Measures:** The Cyber Security Questionnaire was downloaded and will be passed to the school's IT Technician or completion. This information may be required when completing the Record of Processing and data mapping.

**School Server:** Is in a locked room and maintained by the school's IT Technician - Net Central. There is a programme for data cleansing the server in consultation with school staff and managed by the Technician.

**School Cameras:** Only designated members of staff can use school cameras and all staff are aware of photo and video guidelines. Student images are uploaded to a designated area on the school server. Memory cards are cleansed regularly. When recording student images relating to the EYFS Learning Journey the responsible member of staff is aware of the importance of regularly uploading images to minimize the number of images kept at any one time on a school device. All school cameras are accounted for regularly.

**School Kitchen:** Operated by Vertas. There was no student allergy information on display.

**Student Care Plans:** N/A

**First Aid Records:** Records are routinely removed from daily file and stored securely.

**Chestnut Classroom:** A confidential report relating to a student was found in an in-tray. This was removed immediately.

**Beech Classroom:** There were lists showing student first name and surname recording house points and also PE assessments for swimming. Reduce to first name only.

**Staffroom:** Staff pigeon holes were checked and it was found that one member of staff had left her appraisal paperwork in her pigeon hole. Remind staff to regularly clear their paperwork and not store any confidential files or paperwork in such a space.

## 2. Compliance actions that should now be completed

### Initial documents:

- Privacy Notice
- GDPR Policy
- Data Breach Procedure
- SAR procedure
- Photo and Video consent, guidelines and records

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

### The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

### 2.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: [https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016\\_IRMS\\_Toolkit\\_for\\_Schools\\_v5\\_Master.pdf](https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016_IRMS_Toolkit_for_Schools_v5_Master.pdf)
- DfE toolkit  
[https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment\\_data/file/747620/Data\\_Protection\\_Toolkit\\_for\\_Schools\\_OpenBeta.pdf](https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf) (Annex 5,1)

### 2.2. Staff training

GDPR training has been completed and documented for the majority of staff. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

### 2.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

### 2.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

### 3. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

### 4. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

### 5. Next steps

#### Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

#### 5.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

### 6. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>